

Cybersecurity **Complete Study Notes**

Topics Covered

- ◆ Authentication Mechanisms & Protocols
- ◆ Intrusion Prevention Systems (IPS/IDS)
- ◆ Secure Coding Practices & Vulnerabilities
 - ◆ Risk Management & Frameworks
- ◆ Cyber Laws (IT Act, DPDP, GDPR, Budapest)
 - ◆ Data Privacy & Compliance
 - ◆ Network Security (DMZ, VPN, SSH)
 - ◆ Malware Types & Attack Flows
- ◆ Business Continuity & Disaster Recovery
 - ◆ Incident Response (NIST PICERL)
 - ◆ Kerberos, SSO, AAA Model
 - ◆ TSP, SET, and more

Organised • Visual • Easy to Understand

1. Authentication Mechanisms

Authentication is the process of verifying the identity of a user, device, or system. It answers the question: "Who are you?"

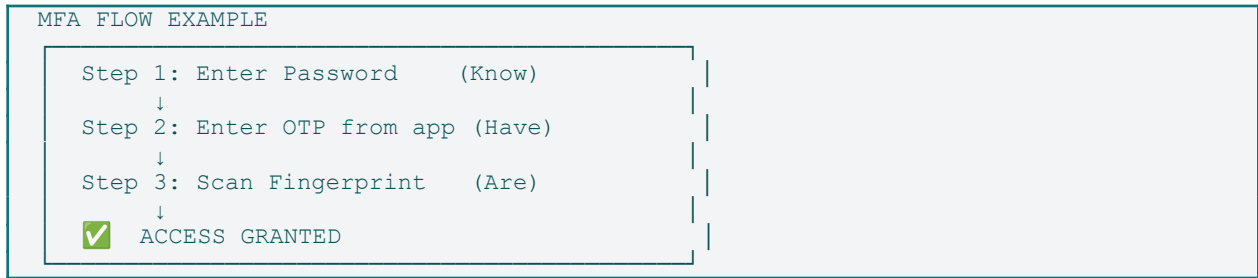
1.1 The Three Factors of Authentication

 Security increases when multiple factors are combined — this is Multi-Factor Authentication (MFA).

Factor	Also Called	What It Is	Examples
Know	Knowledge	Something you know	Password, PIN, Security Question
Have	Possession	Something you have	OTP token, Smart card, Mobile app
Are	Inherence	Something you are	Fingerprint, Retina, Voice, Face ID

1.2 Multi-Factor Authentication (MFA)

MFA requires 2 or more factors from different categories. Combining factors makes unauthorized access exponentially harder.

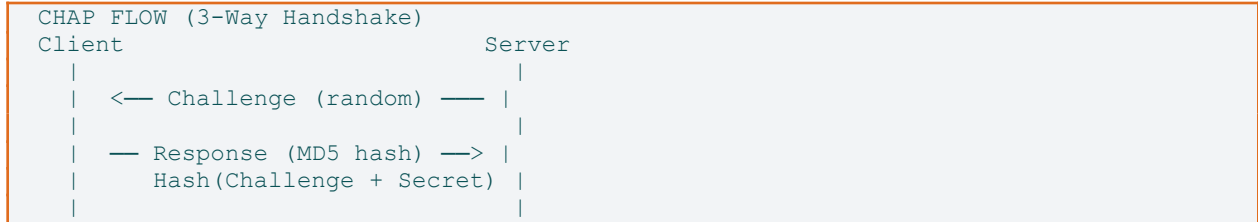


1.3 Authentication Protocols

PAP — Password Authentication Protocol

- Simplest protocol; sends username and password in PLAINTEXT over the network.
- No encryption — extremely insecure. Used only over already-secure channels.
- One-way: client authenticates to server only.

CHAP — Challenge-Handshake Authentication Protocol



- Password is NEVER sent; only a hash of (Challenge + Secret) is transmitted.
- Periodic re-authentication prevents replay attacks.
- NONCE: A random number used once, ensuring each challenge is unique.

EAP — Extensible Authentication Protocol

- Framework that supports many authentication methods (not a single method).
- Common variants: EAP-TLS (certificates), EAP-TTLS, PEAP, EAP-MD5.
- Used widely in Wi-Fi (WPA2/WPA3 Enterprise) and PPP connections.

SAML — Security Assertion Markup Language

- XML-based protocol for exchanging authentication and authorization data.
- Enables Single Sign-On (SSO) across different domains/organisations.
- Three roles: Identity Provider (IdP), Service Provider (SP), User/Principal.

```
SAML SSO FLOW
User → Service Provider (SP) → Identity Provider (IdP)
                                ↓
                        Authenticate User
                                ↓
User ← SP grants access ← SAML Assertion (XML token)
```

1.4 Challenge-Response Systems

Protocol	Algorithm	Use Case	Key Feature
CHAP	MD5	PPP connections	Periodic re-challenge
NTLM	MD4/MD5	Windows domains	No plain-text password
CRAM-MD5	HMAC-MD5	Email (IMAP/SMTP)	Shared secret
Kerberos	AES/DES tickets	Enterprise networks	Tickets, no re-auth

1.5 AAA Model

 AAA = Authentication + Authorization + Accounting — the three pillars of network access control.

AUTHENTICATION	AUTHORIZATION	ACCOUNTING
Who are you? Verify ID Login, certs	What can you do? Assign privileges RBAC, ACLs	What did you do? Logs, audit trails Usage tracking, billing

RADIUS vs TACACS+

Feature	RADIUS	TACACS+
Developed by	Livingston Enterprises	Cisco
Transport	UDP (1812/1813)	TCP (port 49)
Encryption	Encrypts password only	Encrypts entire payload
AAA Separation	Combined Auth+Authz	Fully separates all three
Best For	Network access (ISP)	Device administration
Accounting	Limited detail	Detailed command logging

1.6 Single Sign-On (SSO)

SSO lets users log in once and access multiple applications without re-authenticating.

SSO Technology	Type	How It Works	Use Case
SAML 2.0	XML assertions	IdP issues XML token to SP	Enterprise web apps
OAuth 2.0	Authorization framework	Token-based delegated access	API access (social login)
OpenID Connect	Identity layer on OAuth 2.0	ID tokens (JWT) verify identity	Modern web/mobile SSO
Kerberos	Ticket-based	KDC issues tickets (TGT → ST)	Windows/AD environments

SSO Advantages	SSO Risks
Single credential to remember	Single point of failure
Reduced password fatigue	Credential compromise affects all apps
Centralized access control	Requires robust IdP security
Faster user access	Harder to implement across diverse systems

1.7 Kerberos — Key Components & Working

 Kerberos is a network authentication protocol using tickets to allow nodes to prove their identity securely.

KEY COMPONENTS
KDC (Key Distribution Center) = AS + TGS └ AS (Authentication Server) – verifies user └ TGS (Ticket Granting Server) – issues tickets TGT – Ticket Granting Ticket (proof of identity) ST – Service Ticket (access specific service) Realm – Administrative domain

KERBEROS FLOW (Step by Step)

1. Client → AS: 'I am Alice, give me a TGT'
(sends username + timestamp encrypted with password hash)
2. AS → Client: TGT (encrypted with KDC secret)
+ Session Key (encrypted with Alice's password hash)
3. Client → TGS: 'I want to access FileServer'
(sends TGT + Authenticator encrypted with Session Key)
4. TGS → Client: Service Ticket (ST) for FileServer
+ New session key for FileServer communication
5. Client → FileServer: ST + Authenticator
6. FileServer → Client: Confirms identity, grants access ✓

1.8 Access Control Models

Model	Who Controls Access?	Based On	Example
DAC	Data owner	Identity/ownership	File permissions in Windows
MAC	System/policy	Sensitivity labels	Military classified data
RBAC	Administrator	Job roles	Employee → Manager → Admin
ABAC	Policy engine	Attributes (time, location, role)	Zero-trust environments

 **ACL (Access Control List)** = list of who can access a resource (attached to the resource).
Capability List = list of what resources a subject can access (attached to the user).

1.9 Password Storage Best Practices

Never store plain-text passwords!

Method	What It Does	Security Level	Notes
Plain Text	Stores password as-is	✗ Zero	Never acceptable
MD5/SHA-1 Hash	One-way hash	⚠ Weak	Vulnerable to rainbow tables
Salted Hash	Hash + unique random salt	✓ Good	Prevents rainbow table attacks
bcrypt	Adaptive hash with cost factor	✓✓ Strong	Industry standard, slow by design
Argon2	Memory-hard algorithm (winner of PHC)	✓✓✓ Best	Resistant to GPU attacks

SALTING EXPLAINED

Password: 'mypassword'

Salt: 'xK9\$mQ2p' (random, unique per user)

Hash: bcrypt('mypassword' + 'xK9\$mQ2p', cost=12)

↓

Stored: \$2b\$12\$[salt][hash] (all in one string)

Even if two users have same password → different hashes! 

2. Intrusion Prevention & Detection Systems

2.1 IDS vs IPS — Core Comparison

 *IDS = Intrusion Detection System (watches and alerts). IPS = Intrusion Prevention System (watches and BLOCKS).*

Feature	IDS	IPS
Function	Detect & Alert	Detect & Block/Prevent
Placement	Passive (out-of-band)	Inline (in traffic path)
Response	Sends alert to admin	Drops/rejects malicious traffic
Network Impact	No impact on traffic flow	Adds slight latency
False Positive Risk	Alert fatigue	Blocks legitimate traffic
Analogy	Security camera (records)	Security guard (stops intruder)

2.2 Types of IPS

Type	Full Name	Where It Runs	Protects Against
NIPS	Network-based IPS	Network perimeter/inline	Network-level attacks, port scans
HIPS	Host-based IPS	On individual endpoints	OS-level exploits, malware execution
WIPS	Wireless IPS	Wi-Fi infrastructure	Rogue APs, Evil Twin attacks
NGIPS	Next-Gen IPS	Network (cloud/on-prem)	Deep packet inspection, app-aware

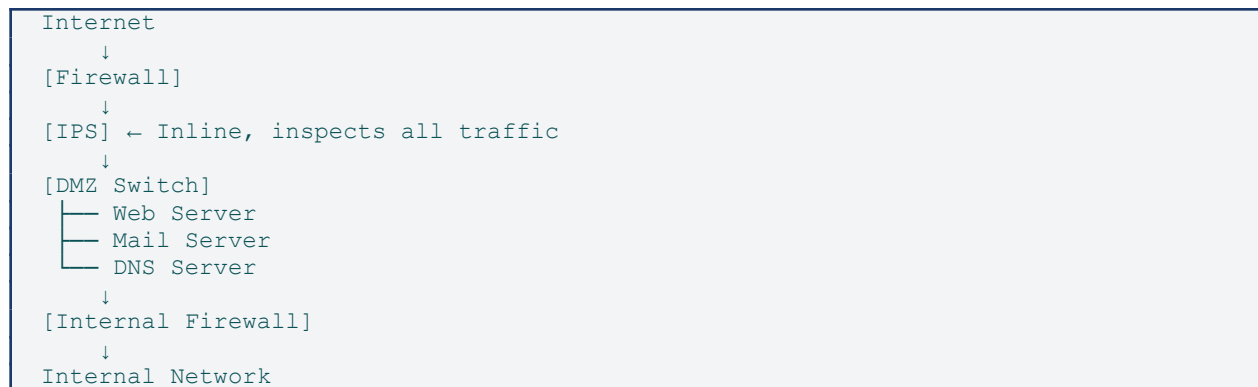
2.3 Detection Methods

Method	How It Works	Pros	Cons
Signature-based	Matches known attack patterns/signatures	Low false positives	Cannot detect zero-day attacks
Anomaly-based	Detects deviation from baseline behaviour	Detects new threats	Higher false positive rate
Policy-based	Alerts on policy/rule violations	Clear, deterministic	Requires well-defined policies
Reputation-based	Checks IP/URL against threat intel feeds	Real-time threat data	Depends on feed quality
Heuristic-based	AI/ML pattern analysis on behaviour	Proactive detection	Complex, computationally expensive

2.4 IPS Actions

- Drop / Block — Silently discard malicious packets.
- Reject — Drop packet and send TCP RST/ICMP unreachable to source.
- Alert — Log and notify administrator (IDS mode).
- Rate-limit — Throttle traffic from suspicious source.
- Quarantine — Isolate compromised host from network.
- Honeypot Redirect — Send attacker to decoy system.

2.5 IPS Placement in Network



3. Secure Coding Practices

3.1 OWASP Top 10 (2021)

 OWASP = Open Web Application Security Project. The Top 10 lists the most critical web security risks.

#	Vulnerability	What It Means	Prevention
A01	Broken Access Control	Users act outside their permissions	Enforce least privilege, deny by default
A02	Cryptographic Failures	Sensitive data exposed (weak/no encryption)	Use TLS, bcrypt, AES-256; no MD5
A03	Injection (SQL/OS/LDAP)	Untrusted data sent to interpreter	Parameterised queries, input validation
A04	Insecure Design	Missing security by design	Threat modelling, secure SDLC
A05	Security Misconfiguration	Default creds, open cloud, verbose errors	Hardening, disable defaults, review configs
A06	Vulnerable Components	Using libraries with known CVEs	SCA tools, patch management, update regularly
A07	Auth & Session Failures	Weak passwords, session fixation	MFA, secure session tokens, account lockout
A08	Software & Data Integrity Failures	Unsigned updates, insecure CI/CD	Verify signatures, code reviews
A09	Logging & Monitoring Failures	Attacks undetected due to poor logging	Centralised logging, SIEM, alerts
A10	SSRF	Server tricked into fetching internal resources	Validate/allow-list URLs, block internal IPs

3.2 Core Secure Coding Principles

Input Validation

- Validate ALL input: length, type, format, range, characters.
- Use allow-list (whitelist) not deny-list (blacklist).
- Validate on server-side — never trust client-side validation alone.

Parameterised Queries (Prevent SQL Injection)

 **VULNERABLE:**
`query = 'SELECT * FROM users WHERE name=' + userInput`
`Input: ' OR 1=1 -- → Dumps entire database!`

```

✓ SAFE (Parameterised):
query = 'SELECT * FROM users WHERE name = ?'
stmt.execute(query, [userInput])
The input is treated as DATA, not code.

```

Buffer Overflow

Occurs when more data is written to a buffer than it can hold, overwriting adjacent memory.

Stack Memory Layout:

Return Addr	← High address
Saved EBP	← Attacker overwrites this!
Local vars	
Buffer[8]	← Input of 20 bytes overflows here
	← Low address

Heap Overflow: overflows dynamically allocated memory

Defense	How It Helps
ASLR (Address Space Layout Randomisation)	Randomises memory addresses — attacker can't predict where to jump
Stack Canaries	Places a 'canary' value before return address — if changed, program aborts
NX/DEP Bit	Marks stack/heap as non-executable — prevents running shellcode
Safe Functions	Use strncpy, snprintf instead of strcpy, sprintf

Format String Attacks

```

✗ VULNERABLE:
printf(userInput); // if input = '%x %x %x' — leaks memory!

✓ SAFE:
printf('%s', userInput); // format string is fixed by programmer

```

Race Condition / TOCTOU

- Time-of-Check to Time-of-Use: the state changes between when you check and when you use it.
- Fix: atomic operations, file locking (flock), transactions in databases.

Integer Overflow

```

int x = 2147483647; // INT_MAX
x = x + 1;          // wraps to -2147483648 (negative!)

Impact: Memory allocation becomes tiny → buffer overflow downstream
Fix: Use size_t, bounds checking, safe integer libraries

```

3.3 Core Security Design Principles

Principle	Meaning	Example
Defence in Depth	Multiple layers of security	Firewall + IPS + WAF + Antivirus + EDR
Least Privilege	Minimum access needed for the task	DB app gets SELECT only, not DROP
Fail-Safe Defaults	Default is deny; access must be explicitly granted	Firewall blocks all by default
Secure by Design	Security built in, not bolted on	HTTPS enforced from day one
Economy of Mechanism	Keep design simple — complexity hides bugs	Small, auditable codebase
Separation of Duties	No single person can complete critical task alone	Two-person integrity for key signing

3.4 Secure SDLC Phases

SECURE SOFTWARE DEVELOPMENT LIFE CYCLE

1. REQUIREMENTS → Define security requirements, classify data
↓
2. DESIGN → Threat modelling (STRIDE), architecture review
↓
3. DEVELOPMENT → Secure coding standards, peer code review
↓
4. TESTING → SAST, DAST, penetration testing, fuzzing
↓
5. DEPLOYMENT → Hardened config, least-privilege accounts
↓
6. MAINTENANCE → Patch management, monitoring, incident response

4. Risk Management

4.1 Key Definitions

Term	Definition	Example
Asset	Anything of value to the organisation	Customer database, source code
Threat	Potential cause of unwanted incident	Hacker, ransomware, earthquake
Vulnerability	Weakness that can be exploited	Unpatched OS, weak password
Risk	Probability × Impact of a threat exploiting a vulnerability	Data breach likelihood × financial loss
Exposure	Degree to which an asset is open to damage	Public-facing server without WAF
Control/Safeguard	Measure to reduce risk	Firewall, encryption, training

4.2 The 5-Step Risk Management Process

Step 1: IDENTIFY	→ List all assets, threats, and vulnerabilities
↓	
Step 2: ASSESS	→ Determine likelihood and impact of each risk
↓	
Step 3: ANALYSE	→ Quantitative (SLE/ALE) or Qualitative (matrix)
↓	
Step 4: RESPOND	→ Choose a risk response strategy
↓	
Step 5: MONITOR	→ Continuously review and update risk posture

4.3 Risk Response Strategies

Strategy	What You Do	When To Use	Example
Avoid	Eliminate the activity causing risk	Risk too high to mitigate	Stop offering a vulnerable feature
Mitigate	Reduce likelihood or impact	Risk can be reduced cost-effectively	Install firewall, patch systems
Transfer	Shift risk to third party	Cost of mitigation > cost of transfer	Buy cyber insurance, outsource
Accept	Acknowledge and do nothing	Risk is low or cost of mitigation > loss	Accept minor operational inconvenience

4.4 Quantitative Risk Formulas

 These formulas assign real dollar values to risk — essential for business decision-making.

KEY FORMULAS

AV = Asset Value (what the asset is worth in \$)
EF = Exposure Factor (% of asset lost per incident, 0-1)
ARO = Annual Rate of Occurrence (expected incidents per year)

SLE = AV × EF (Single Loss Expectancy)
Loss from ONE incident

ALE = SLE × ARO (Annual Loss Expectancy)
Expected yearly loss

EXAMPLE:

Server worth \$100,000 (AV)
Fire destroys 40% of it (EF = 0.4)
Fire expected once in 10 years (ARO = 0.1)
SLE = \$100,000 × 0.4 = \$40,000
ALE = \$40,000 × 0.1 = \$4,000 per year

→ Safeguard costing < \$4,000/yr is worth implementing!

4.5 Security Controls Classification

Type → Purpose ↓	Technical	Administrative	Physical
Preventive	Firewall, encryption, MFA	Security policies, training	Locks, fences, guards
Detective	IDS, SIEM, log analysis	Audits, background checks	CCTV, motion sensors
Corrective	Patching, antivirus quarantine	Incident response plan	Fire suppression systems
Deterrent	Warning banners, honeypots	Non-disclosure agreements	Warning signs, lighting

4.6 Business Continuity & DR

Term	Definition
RTO	Recovery Time Objective — Max acceptable downtime after disaster
RPO	Recovery Point Objective — Max acceptable data loss (time-based)
MTD	Maximum Tolerable Downtime — Absolute maximum before business fails
BIA	Business Impact Analysis — Identifies critical functions and their dependencies

Disaster Recovery Sites

Site Type	Readiness	Cost	Recovery Time	Description
Hot Site	Fully operational	Highest	Minutes to hours	Mirror of production; live data sync
Warm Site	Partially configured	Medium	Hours to days	Hardware ready; data restored from backup
Cold Site	Empty facility	Lowest	Days to weeks	Just space & power; everything else shipped
Cloud Site	On-demand	Variable	Minutes (auto-scale)	AWS/Azure/GCP disaster recovery

Backup Types & 3-2-1 Rule

Type	What It Backs Up	Restore Time	Storage Need
Full Backup	Everything, every time	Fastest	Largest
Differential	Changes since last FULL backup	Medium	Medium
Incremental	Changes since last backup (any type)	Slowest	Smallest

 **3-2-1 Rule:** Keep 3 copies of data, on 2 different media types, with 1 copy off-site (or cloud).

4.7 Major Risk Frameworks

Framework	Origin	Focus	Key Feature
ISO/IEC 27001	ISO/IEC	Information Security Management System (ISMS)	Certifiable international standard
NIST CSF	NIST (USA)	Cybersecurity risk framework	5 functions: Identify, Protect, Detect, Respond, Recover
NIST SP 800-53	NIST (USA)	Security controls for federal systems	800+ controls across 20 families
COBIT	ISACA	IT governance and management	Links business goals to IT controls
PCI DSS	Payment card industry	Payment data security	12 requirements for card processing

4.8 Incident Response — NIST PICERL Model

Phase 1: PREPARATION	→ Policies, tools, team training, playbooks
↓	
Phase 2: IDENTIFICATION	→ Detect the incident; analyse alerts/logs
↓	
Phase 3: CONTAINMENT	→ Stop the spread; isolate affected systems
↓	
Phase 4: ERADICATION	→ Remove malware, close vulnerabilities

↓

Phase 5: RECOVERY → Restore systems; verify integrity; return to ops

↓

Phase 6: LESSONS LEARNED → Document findings; improve defences

5. Cyber Laws

5.1 India — IT Act 2000

 The Information Technology Act 2000 is India's primary law governing cybercrime and electronic commerce.

Section	Topic	Offence / Provision	Punishment
Sec 43	Damage to computer	Unauthorised access, data theft, virus introduction	Civil liability — compensation
Sec 65	Tampering source code	Concealing/altering source code intentionally	3 years / ₹2 lakh fine
Sec 66	Computer-related offences	Hacking, dishonest/fraudulent computer acts	3 years / ₹5 lakh fine
Sec 66A	Offensive messages	Sending menacing/false online messages (struck down SC 2015)	Repealed
Sec 66B	Stolen computer resource	Receiving stolen device/data dishonestly	3 years / ₹1 lakh fine
Sec 66C	Identity theft	Fraudulently using another's electronic signature/password	3 years / ₹1 lakh fine
Sec 66D	Cheating by impersonation	Impersonating another person using a computer	3 years / ₹1 lakh fine
Sec 66E	Privacy violation	Capturing/publishing private images without consent	3 years / ₹2 lakh fine
Sec 66F	Cyber terrorism	Acts threatening unity, sovereignty, or causing death via cyberspace	Life imprisonment
Sec 67	Obscene material	Publishing/transmitting obscene content online	5 years / ₹10 lakh fine
Sec 69	Interception/monitoring	Govt power to intercept data for national security	Govt powers
Sec 70	Protected systems	Accessing government-notified critical infrastructure	10 years imprisonment
Sec 79	Intermediary liability	Safe harbour for intermediaries if due diligence followed	Exemption from liability

5.2 India — DPDP Act 2023

The Digital Personal Data Protection Act 2023 is India's comprehensive data protection law.

- Applies to processing of digital personal data within India and processing outside India if related to Indian residents.
- Data Principal: The individual whose data is processed (the user).

- Data Fiduciary: The entity that determines the purpose and means of processing (like a company).
- Consent: Must be free, specific, informed, and unconditional before processing data.
- Purpose Limitation: Data used only for the specified purpose it was collected for.
- Data Localisation: Certain sensitive data must be stored in India (to be notified).
- Children's Data: Parental consent required; no behavioural tracking of children.
- Data Protection Board: Regulatory authority to handle complaints and impose penalties.
- Penalties: Up to ₹250 crore per breach violation.

5.3 Budapest Convention

 *The Budapest Convention (2001) is the first international treaty on cybercrime, developed by the Council of Europe.*

- Covers: Illegal access, data interference, system interference, computer forgery, computer fraud.
- Requires signatory nations to harmonise domestic laws on cybercrime.
- Enables cross-border cooperation and fast-track mutual legal assistance.
- India is not a signatory but has observer status.

5.4 GDPR — General Data Protection Regulation (EU)

GDPR Principle	What It Means
Lawfulness, Fairness & Transparency	Data processed lawfully with clear communication to individuals
Purpose Limitation	Collected for specific, explicit purposes only
Data Minimisation	Collect only what is necessary
Accuracy	Data must be kept accurate and up-to-date
Storage Limitation	Not stored longer than necessary
Integrity & Confidentiality	Protected against unauthorised processing and loss
Accountability	Controller must demonstrate compliance

- Right to be Forgotten: Individuals can request deletion of their data.
- Data Portability: Right to receive data in machine-readable format.
- 72-Hour Breach Notification: Must notify authorities within 72 hours of a data breach.
- DPO (Data Protection Officer): Required for large-scale processing of sensitive data.
- Penalties: Up to €20 million or 4% of global annual turnover (whichever is higher).

6. Data Privacy & Compliance

6.1 Core Privacy Principles (FIPPs)

Fair Information Practice Principles — the foundation of modern privacy law worldwide.

Principle	Description
Notice/Awareness	Users must be informed about data collection practices
Choice/Consent	Users must have options about how their data is used
Access/Participation	Users can view and correct their own data
Integrity/Security	Data must be accurate and protected from unauthorised access
Enforcement/Redress	Mechanisms to enforce rights and provide remedies

6.2 Sensitive Data Categories

Category	Examples	Why Sensitive
Health/Medical	Medical records, diagnoses, prescriptions	Discrimination, insurance abuse
Financial	Bank accounts, credit scores, tax data	Identity theft, fraud
Biometric	Fingerprints, face scan, iris data	Cannot be changed if breached
Children's Data	Age, location, browsing habits of minors	Vulnerability of minors
Racial/Ethnic Origin	Nationality, ethnicity, religion	Discrimination risk
Sexual Orientation	Partner preferences, gender identity	Social/legal vulnerability
Criminal Records	Past convictions, pending charges	Stigma, employment impact

6.3 Privacy by Design (PbD) — 7 Principles

1. Proactive not Reactive — prevent privacy issues before they occur.
2. Privacy as Default — maximum privacy without user action required.
3. Privacy Embedded into Design — built in, not added later.
4. Full Functionality — privacy AND functionality (not a trade-off).
5. End-to-End Security — full lifecycle protection of data.
6. Visibility & Transparency — open standards and practices.
7. Respect for User Privacy — user-centric design.

6.4 Data Breach Management Steps

1. DETECT → Identify that a breach has occurred
↓
2. CONTAIN → Stop further data loss immediately
↓
3. ASSESS → Determine scope, type of data, affected individuals
↓
4. NOTIFY → Inform regulators (within 72 hrs for GDPR)
Notify affected individuals if high risk
↓
5. REMEDIATE → Fix the vulnerability, patch systems
↓
6. REVIEW → Update policies, train staff, audit controls

7. Network Security

7.1 DMZ — Demilitarised Zone

 A DMZ is a network segment that separates the public internet from the internal private network, hosting publicly accessible services.

Servers Typically in a DMZ

- Web Servers (HTTP/HTTPS)
- Mail Servers (SMTP)
- DNS Servers (external-facing)
- FTP Servers
- Reverse Proxies / Load Balancers

DMZ Architectures

```
SINGLE FIREWALL (3-legged)
Internet —[Firewall]—— DMZ
                  |
                  Internal LAN

DUAL FIREWALL (More Secure)
Internet —[Outer FW]— DMZ —[Inner FW]— Internal LAN
If outer firewall is breached, inner FW still protects LAN
```

7.2 SSH vs Telnet

Feature	SSH	Telnet
Security	Encrypted (AES, ChaCha20)	Plain text — NO encryption
Port	TCP 22	TCP 23
Authentication	Password + Public key + 2FA	Password only (sent in clear!)
Integrity	HMAC for message integrity	No integrity check
Use Case	Secure remote admin (standard)	Legacy systems only
Recommendation	✅ Always use SSH	❌ Never on production

SSH Key-Based Authentication

1. Generate key pair: `ssh-keygen -t ed25519`
 - Private key: stays on CLIENT (never share!)
 - Public key: copied to SERVER (`~/.ssh/authorized_keys`)
2. Client connects → Server sends challenge
3. Client signs challenge with Private Key
4. Server verifies signature with Public Key → Access granted ✅

No password sent over network — immune to password interception!

7.3 VPN Tunneling Protocols

Protocol	Security	Speed	Port	Notes
PPTP	✗ Weak (MS-CHAPv2)	Fast	TCP 1723	Obsolete, avoid
L2TP/IPsec	✓ Strong (AES)	Medium	UDP 500/1701	Double encapsulation overhead
OpenVPN	✓✓ Very Strong	Medium	UDP 1194	Open source, TLS-based
WireGuard	✓✓ Best	Fastest	UDP 51820	Modern, lean, ChaCha20
IKEv2/IPsec	✓✓ Strong	Fast	UDP 500/4500	Best for mobile reconnect

Transport Mode vs Tunnel Mode (IPsec)

Mode	What's Encrypted	What's Authenticated	Use Case
Transport Mode	Payload (data) only	IP Header + Payload	Host-to-host encryption
Tunnel Mode	Entire original IP packet	New IP Header + Entire original packet	Site-to-site VPN gateway

8. Malware

8.1 Ransomware

 Ransomware encrypts victim's files and demands a ransom (usually cryptocurrency) for the decryption key.

Ransomware Attack Flow

1. DELIVERY	Phishing email / Exploit kit / RDP brute-force
↓	
2. EXECUTION	Malware runs on victim machine
↓	
3. C2 CONTACT	Malware contacts attacker server (C&C)
↓	
4. KEY EXCHANGE	Attacker sends RSA Public Key
↓	
5. ENCRYPTION	Files encrypted with AES-256 (symmetric key) AES key encrypted with RSA Public Key
↓	
6. RANSOM NOTE	'Pay X Bitcoin to get decryption key'
↓	
7. PAYMENT	Victim pays → Attacker sends RSA Private Key
↓	
8. DECRYPTION	RSA Private Key decrypts AES Key → files restored

WannaCry (2017) — Notable Case

- Exploited EternalBlue (NSA exploit for Windows SMB vulnerability — MS17-010).
- Spread automatically across networks — a worm + ransomware hybrid.
- Infected 200,000+ systems in 150 countries in 4 days.
- UK NHS severely impacted; damage estimated at \$4–8 billion.
- Kill switch: researcher found a domain in code; registering it stopped propagation.

8.2 Spyware

- Secretly monitors user activity and exfiltrates data without consent.
- Collects: keystrokes, screenshots, webcam feeds, browsing history, credentials.
- Often bundled with freeware or installed via browser exploits.
- Examples: Pegasus (commercial spyware), FinFisher, keyloggers.

8.3 Rootkits — 5 Types

Type	Where It Hides	Detection Difficulty	Example
User-mode	Application / API layer	Moderate	Hooks user-space system calls
Kernel-mode	OS kernel	High	Modifies kernel data structures

Type	Where It Hides	Detection Difficulty	Example
Bootkits	MBR / boot sector	Very High	Loads before OS — survives reinstall
Hypervisor	Below the OS (virtual layer)	Extremely High	Blue Pill rootkit
Firmware	BIOS/UEFI	Near impossible	Persists across full OS reinstall

8.4 Keyloggers

Type	How It Works	Detection
Software Keylogger	Hook keyboard API at OS level; intercept keystrokes	Antivirus, process monitoring
Hardware Keylogger	Physical device between keyboard and computer	Physical inspection only
Acoustic Keylogger	Analyses keystroke sounds via microphone	Hard — no software trace
Electromagnetic	Captures EM emanations from keyboard cable	Requires specialised equipment

9. Special Protocols — TSP, SET, IDS Deep Dive

9.1 TSP — Trusted Timestamping Protocol

 TSP creates a trusted, tamper-proof timestamp on digital documents — proving they existed at a specific point in time.

TSP FLOW (RFC 3161)

1. Client computes hash of document (SHA-256)
↓
2. Client sends hash to TSA (Timestamp Authority)
↓
3. TSA creates TimestampToken:
{ hash, exact time, TSA identity } signed with TSA private key
↓
4. Client receives and stores the TimestampToken
↓
5. Anyone can VERIFY by checking TSA's public key signature 

- Use cases: Legal documents, software signing, audit logs, digital signatures.
- TSA (Timestamp Authority) is a trusted third party — like a notary for digital files.
- Even if the TSA is offline later, the signed token remains verifiable.

9.2 SET — Secure Electronic Transaction

 SET was designed by Visa/Mastercard in 1996 to secure online credit card payments using digital certificates.

SET Participants

- Cardholder — buyer with a credit card.
- Merchant — online seller.
- Payment Gateway — connects merchant to bank.
- Issuing Bank — cardholder's bank (issues the card).
- Acquiring Bank — merchant's bank.
- Certificate Authority (CA) — issues digital certificates to all parties.

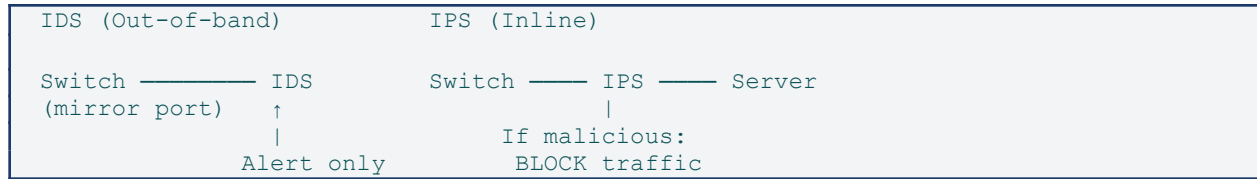
SET KEY FEATURES

-  Dual Signature: Merchant sees order, NOT card details
Bank sees card details, NOT order details
Privacy preserved via linked digests
-  Certificates: All parties have X.509 certificates
Ensures authenticity of everyone involved
-  Encryption: RSA for key exchange, DES for data

✗ Limitation: Complex, expensive – replaced by SSL/TLS + 3D Secure

9.3 IDS — Intrusion Detection System (Deep Dive)

IDS vs IPS Positioning



IDS Components

- Sensor/Agent — collects data (packets, logs, system calls).
- Analyser — processes data and compares against rules/baseline.
- Alert System — generates alerts when anomalies detected.
- Management Console — central dashboard for monitoring and tuning.

True/False Positives & Negatives

	Intrusion Present	No Intrusion
Alert Raised	True Positive ✓	False Positive ✗
No Alert	False Negative ✗✗	True Negative ✓

⚠ False Negatives (missed attacks) are the most dangerous! False Positives cause alert fatigue.

10. Security Policies & Summary Reference

10.1 Common Security Policies

Policy	Purpose	Key Contents
AUP (Acceptable Use Policy)	Define acceptable use of IT resources	Permitted activities, prohibited uses, monitoring rights
Data Classification Policy	Categorise data by sensitivity	Public, Internal, Confidential, Top Secret — handling rules
BYOD Policy	Rules for personal devices at work	MDM requirements, approved apps, remote wipe consent
Password Policy	Enforce strong passwords	Length, complexity, rotation, no reuse
Incident Response Policy	Define IR procedures	Roles, escalation paths, notification timelines
Remote Access Policy	Govern VPN and remote work	VPN requirements, MFA mandate, approved devices
Change Management Policy	Control system changes	Approval process, rollback plans, testing requirements

10.2 Quick Reference — All Key Acronyms

Acronym	Stands For	Domain
MFA	Multi-Factor Authentication	Auth
SSO	Single Sign-On	Auth
SAML	Security Assertion Markup Language	Auth
PAP/CHAP/EAP	Password/Challenge/Extensible Auth Protocols	Auth
AAA	Authentication, Authorization, Accounting	Auth
IDS/IPS	Intrusion Detection/Prevention System	Network
NIPS/HIPS/WIPS	Network/Host/Wireless IPS	Network
DMZ	Demilitarised Zone	Network
VPN	Virtual Private Network	Network
OWASP	Open Web Application Security Project	Coding
ASLR/NX/DEP	Memory Protection Mechanisms	Coding
SDLC	Software Development Life Cycle	Coding
SLE/ALE/ARO	Risk Quantification Formulas	Risk

Acronym	Stands For	Domain
BIA/RTO/RPO /MTD	Business Continuity Metrics	Risk
NIST CSF	NIST Cybersecurity Framework	Risk
ISO 27001	Information Security Mgmt Standard	Risk
GDPR	General Data Protection Regulation (EU)	Law
DPDP	Digital Personal Data Protection Act (India)	Law
TSP	Trusted Timestamping Protocol	Protocol
SET	Secure Electronic Transaction	Protocol
PICERL	Prepare/Identify/Contain/Eradicate/Rec over/Lessons	IR

 You've completed all sections! Review diagrams and tables frequently for effective retention.
 Good luck! 